Практическая работа 1. Законодательство в области информационной безопасности

1.1. Теоретическая часть

Нормативно-правовые документы в области информационной безопасности в РФ

Законодательная база в сфере информационной безопасности состоит из Федеральных законов, Указов Президента РФ, постановлений Правительства РФ, межведомственных руководящих документов и стандартов.

На рис. 1 представлены основные нормативно-правовые документы в области информационной безопасности в РФ.

Рис. 1. Нормативно-правовые документы в области информационной безопасности в РФ

Основным законом Российской Федерации является Конституция РФ, принятая 12 декабря 1993 г.

В соответствии со статьей 24 Конституции, органы государственной власти и органы местного самоуправления, их должностные лица обязаны обеспечить каждому возможность ознакомления с документами и материалами, непосредственно затрагивающими его права и свободы, если иное не предусмотрено законом.

Статья 41 Конституции гарантирует право на знание фактов и обстоятельств, создающих угрозу для жизни и здоровья людей; статья 42 – право на знание достоверной информации о состоянии окружающей среды.

Статья 23 Конституции гарантирует право на личную и семейную тайну, на тайну переписки, телефонных переговоров, почтовых, телеграфных и иных сообщений; статья 29 – право свободно искать, получать, передавать,

производить и распространять информацию любым законным способом. Современная интерпретация этих положений включает обеспечение конфиденциальности данных, в том числе в процессе их передачи по компьютерным сетям, а также доступ к средствам защиты информации.

В Гражданском кодексе Российской Федерации фигурируют такие понятия, как банковская, коммерческая и служебная тайна. Согласно статье 139, информация составляет служебную или коммерческую тайну в случае, когда информация имеет действительную или потенциальную коммерческую ценность в силу неизвестности ее третьим лицам, к ней нет свободного доступа на законном основании, и обладатель информации принимает меры к охране ее конфиденциальности.

Весьма продвинутым в плане информационной безопасности является Уголовный кодекс Российской Федерации. Глава 28 «Преступления в сфере компьютерной информации» содержит три статьи:

– статья 272. Неправомерный доступ к компьютерной информации;

– статья 273. Создание, использование и распространение вредоносных компьютерных программ;

– статья 274. Нарушение правил эксплуатации средств хранения, обработки или передачи компьютерной информации и информационно-телекоммуникационных сетей.

Первая имеет дело с посягательствами на конфиденциальность, вторая – с вредоносным ПО, третья – с нарушениями доступности и целостности, повлекшими за собой уничтожение, блокирование или модификацию охраняемой законом компьютерной информации. Включение в сферу действия УК РФ вопросов доступности информационных сервисов является очень актуальным.

Статья 138 УК РФ, защищая конфиденциальность персональных данных, предусматривает наказание за нарушение тайны переписки, телефонных переговоров, почтовых, телеграфных или иных сообщений. Аналогичную роль для банковской и коммерческой тайны играет статья 183 УК РФ.

Интересы государства в плане обеспечения конфиденциальности информации наиболее полно выражены в законе «О государственной тайне». В нем гостайна определена как защищаемые государством сведения в области военной, внешнеполитической, экономической, разведывательной, контрразведывательной и оперативно-розыскной деятельности, распространение которых может нанести ущерб безопасности Российской Федерации. Там же дается определение средствам защиты информации – это технические, криптографические, программные и другие средства, предназначенные для защиты сведений, составляющих государственную тайну; средства, в которых они реализованы, а также средства контроля эффективности защиты информации.

Основополагающим среди российских законов, посвященных вопросам информационной безопасности, является закон «Об информации, информационных технологиях и о защите информации» от 27 июля 2006 г. номер 149-ФЗ (принят Государственной Думой 8 июля 2006 г.). В нем даются основные определения, намечаются направления, в которых должно развиваться законодательство в данной области, регулируются отношения,

возникающие при:

– осуществлении права на поиск, получение, передачу, производство и распространение информации;

– применении информационных технологий;

– обеспечении защиты информации.

Статья 16 целиком посвящена вопросам защиты информации. В этой статье Закона фигурируют все три основных аспекта информационной безопасности: доступность, целостность и конфиденциальность. Кроме того, обязательным является отслеживание нарушений безопасности и постоянный контроль за обеспечением уровня защищенности информации.

Президент подписал очень важный закон «Об электронной подписи» номер 63-ФЗ (принят Государственной Думой 6 апреля 2011 г.).

Принят Федеральный закон «О Персональных данных» от 27 июля 2006 г. номер 152-ФЗ (с изм. и доп. 01.03.2021 г.). В статье 2 сформулирована цель Федерального закона: обеспечение защиты прав и свобод человека и гражданина при обработке его персональных данных, в том числе защиты прав на неприкосновенность частной жизни, личную и семейную тайну.

Кроме того, хранение персональных данных должно осуществляться в форме, позволяющей определить субъекта персональных данных, не дольше, чем этого требуют цели их обработки, и они подлежат уничтожению по достижении целей обработки или в случае утраты необходимости в их достижении.

Основными задачами системы защиты информации, нашедшими отражение в Законе «Об информации, информационных технологиях и о защите информации», являются:

– предотвращение утечки, хищения, утраты, модификации (подделки), несанкционированного уничтожения, искажения, несанкционированного копирования, блокирования информации и т. п., вмешательства в информацию и информационные системы;

– сохранение полноты, достоверности, целостности информации, ее массивов и программ обработки данных, установленных собственником или уполномоченным им лицом;

– сохранение возможности управления процессом обработки, пользования информацией в соответствии с условиями, установленными собственником или владельцем информации;

– обеспечение конституционных прав граждан на сохранение личной тайны и конфиденциальности персональной информации, накапливаемой в банках данных;

– сохранение секретности или конфиденциальности информации в соответствии с правилами, установленными действующим законодательством и другими законодательными или нормативными актами;

– соблюдение прав авторов программно-информационной продукции, используемой в информационных системах.

Законом определено, что средства защиты информации должны иметь сертификат, удостоверяющий их соответствие требованиям по защите сведений соответствующей степени секретности.

Организация сертификации средств защиты информации возлагается на

Государственную техническую комиссию при Президенте РФ, Федеральную службу безопасности РФ и Министерство обороны РФ.

Ответственность за нарушения в сфере информационной безопасности

Немаловажная роль в системе правового регулирования информационных отношений отводится ответственности субъектов за нарушения в сфере информационной безопасности.

Основными документами в этом направлении являются:

– Уголовный кодекс Российской Федерации.

– Кодекс Российской Федерации об административных правонарушениях.

В Уголовном кодексе Российской Федерации **(**принятом в 1996 г.**)**, как наиболее сильнодействующем законодательном акте по предупреждению преступлений и привлечению преступников и нарушителей к уголовной ответственности, вопросам безопасности информации посвящены следующие главы и статьи:

– Статья 138. Нарушение тайны переписки, телефонных переговоров, почтовых, телеграфных или иных сообщений.

– Статья 140. Отказ в предоставлении гражданину информации.

– Статья 183. Незаконные получение и разглашение сведений, составляющих коммерческую, налоговую или банковскую тайну.

– Статья 237. Сокрытие информации об обстоятельствах, создающих опасность для жизни или здоровья людей.

– Статья 283. Разглашение государственной тайны.

– Статья 284. Утрата документов, содержащих государственную тайну.

Особое внимание уделяется компьютерным преступлениям, ответственность за которые предусмотрена в специальной 28 главе кодекса «Преступления в сфере компьютерной информации» в статьях 272, 273, 274.

Статья 272. Неправомерный доступ к компьютерной информации.

1. Неправомерный доступ к охраняемой законом компьютерной информации, если это деяние повлекло уничтожение, блокирование, модификацию либо копирование компьютерной информации, – наказывается штрафом в размере до двухсот тысяч рублей или в размере заработной платы, или иного дохода осужденного за период до восемнадцати месяцев, либо исправительными работами на срок до одного года, либо ограничением свободы на срок до двух лет, либо принудительными работами на срок до двух лет, либо лишением свободы на тот же срок.

2. То же деяние, причинившее крупный ущерб или совершенное из корыстной заинтересованности, – наказывается штрафом в размере от ста тысяч до трехсот тысяч рублей или в размере заработной платы или иного дохода осужденного за период от одного года до двух лет, либо исправительными работами на срок от одного года до двух лет, либо ограничением свободы на срок до четырех лет, либо принудительными работами на срок до четырех лет, либо лишением свободы на тот же срок.

3. Деяния, предусмотренные частями первой или второй настоящей

статьи, совершенные группой лиц по предварительному сговору или организованной группой либо лицом с использованием своего служебного положения, – наказываются штрафом в размере до пятисот тысяч рублей или в размере заработной платы, или иного дохода осужденного за период до трех лет с лишением права занимать определенные должности или заниматься определенной деятельностью на срок до трех лет, либо ограничением свободы на срок до четырех лет, либо принудительными работами на срок до пяти лет, либо лишением свободы на тот же срок.

4. Деяния, предусмотренные частями первой, второй или третьей настоящей статьи, если они повлекли тяжкие последствия или создали угрозу их наступления, – наказываются лишением свободы на срок до семи лет.

Примечания:

– под компьютерной информацией понимаются сведения (сообщения, данные), представленные в форме электрических сигналов, независимо от средств их хранения, обработки и передачи;

– крупным ущербом в статьях настоящей главы признается ущерб, сумма которого превышает один миллион рублей.

Статья 273 УК РФ. Создание, использование и распространение вредоносных компьютерных программ.

1. Создание, распространение или использование компьютерных программ либо иной компьютерной информации, заведомо предназначенных для несанкционированного уничтожения, блокирования, модификации, копирования компьютерной информации или нейтрализации средств защиты компьютерной информации, – наказываются ограничением свободы на срок до четырех лет, либо принудительными работами на срок до четырех лет, либо лишением свободы на тот же срок со штрафом в размере до двухсот тысяч рублей или в размере заработной платы, или иного дохода осужденного за период до восемнадцати месяцев.

2. Деяния, предусмотренные частью первой настоящей статьи, совершенные группой лиц по предварительному сговору или организованной группой, либо лицом с использованием своего служебного положения, а равно причинившие крупный ущерб или совершенные из корыстной заинтересованности, – наказываются ограничением свободы на срок до четырех лет, либо принудительными работами на срок до пяти лет с лишением права занимать определенные должности или заниматься определенной деятельностью на срок до трех лет или без такового, либо лишением свободы на срок до пяти лет со штрафом в размере от ста тысяч до двухсот тысяч рублей или в размере заработной платы, или иного дохода осужденного за период от двух до трех лет или без такового и с лишением права занимать определенные должности или заниматься определенной деятельностью на срок до трех лет или без такового.

3. Деяния, предусмотренные частями первой или второй настоящей статьи, если они повлекли тяжкие последствия или создали угрозу их наступления, – наказываются лишением свободы на срок до семи лет.

Статья 274. Нарушение правил эксплуатации средств хранения, обработки или передачи компьютерной информации и информационно-телекоммуникационных сетей.

1. Нарушение правил эксплуатации средств хранения, обработки или передачи охраняемой компьютерной информации либо информационно-телекоммуникационных сетей и оконечного оборудования, а также правил доступа к информационно-телекоммуникационным сетям, повлекшее уничтожение, блокирование, модификацию либо копирование компьютерной информации, причинившее крупный ущерб, – наказывается штрафом в размере до пятисот тысяч рублей или в размере заработной платы, или иного дохода осужденного за период до восемнадцати месяцев, либо исправительными работами на срок от шести месяцев до одного года, либо ограничением свободы на срок до двух лет, либо принудительными работами на срок до двух лет, либо лишением свободы на тот же срок.

2. Деяние, предусмотренное частью первой настоящей статьи, если оно повлекло тяжкие последствия или создало угрозу их наступления, – наказывается принудительными работами на срок до пяти лет либо лишением свободы на тот же срок.

Стандарты информационной безопасности

К основным нормативно-правовым документам в области информационной безопасности в РФ, кроме актов федерального законодательства и методических документов государственных органов России, относятся стандарты информационной безопасности.

Стандарт информационной безопасности – нормативный документ, определяющий порядок и правила взаимодействия субъектов информационных отношений, а также требования к инфраструктуре информационной системы, обеспечивающие необходимый уровень информационной безопасности.

ГОСТ Р ИСО/МЭК 15408-1-2012 «Информационная технология. Методы и средства обеспечения безопасности. Критерии оценки безопасности информационных технологий. Часть 1. Введение и общая модель» является национальным стандартом РФ. Настоящий стандарт идентичен международному стандарту ИСО/МЭК 15408-1:2009. Он вобрал в себя опыт существовавших к тому времени документов национального и межнационального масштаба. Поэтому этот стандарт часто называют «Общими критериями». В нем определены инструменты оценки безопасности информационных систем и порядок их использования.

«Общие критерии» содержат два основных вида требований безопасности:

– функциональные – соответствуют активному аспекту защиты, предъявляются к функциям безопасности и реализующим их механизмам;

– требования доверия – соответствуют пассивному аспекту, предъявляются к технологии и процессу разработки и эксплуатации.

Угрозы безопасности в стандарте характеризуются параметрами:

– источник угрозы;
– метод воздействия;
– уязвимые места, которые могут быть использованы;
– ресурсы (активы), которые могут пострадать.

Для структуризации пространства требований в «Общих критериях»

введена иерархия класс – семейство – компонент – элемент:

– классы определяют наиболее общую, «предметную» группировку требований (например, функциональные требования подотчетности);

– семейства в пределах класса различаются по строгости и другим тонкостям требований;

– компонент – минимальный набор требований, фигурирующий как целое;

– элемент – неделимое требование.

1.2. Практическая часть

Задача 1

Используя ГОСТ Р ИСО/МЭК 27002-2012, решить ситуационную задачу.

Вы – начальник отдела по вопросам информационной безопасности в некоторой некрупной организации (20-30 человек).

Вам необходимо разработать комплекс мероприятий (от 10 до 20) по следующему направлению: привлечение сторонних организаций к обработке информации.

Цель: обеспечение информационной безопасности при передаче ответственности за обработку информации другой организации.

Изучить разделы ГОСТ Р ИСО/МЭК 27002-2012.

Задача 2

Используя основные положения части 4, главы 70 Гражданского кодекса РФ, решить ситуационную задачу.

Гражданин Смирнов А.В. создал инструментальное программное средство для работы с трехмерной компьютерной графикой под названием «Albert 3D» и зарегистрировал на него свои права. 15.09.2019 этот гражданин заключил договор с компанией «MosTechnology» и передал свои имущественные права на распространение своего программного продукта сроком на один год. После заключения договора компания «MosTechnology» распространила версию программы «Albert 3D» с предварительной модификацией данного программного продукта без ведома автора.

Вопрос: Имеет ли место в данной ситуации нарушение авторского права гражданина Смирнова?

Ответ: согласно статьи №….

Задача 3

Используя статьи УК РФ, ответьте на вопросы после ознакомления с ситуацией.

Ситуация: А.Н. Иванов, сотрудник одного из филиалов ИТ-банка, внедрил в компьютерную банковскую систему вирус, уничтожающий исполняемые файлы (расширение .exe). В результате внедрения этого вируса было уничтожено 40 % банковских программных приложений, что принесло банку материальный ущерб в размере 780000 рублей.

Вопросы:

– Какая статья УК РФ была нарушена?

– Что послужило предметом преступления?

– Какие неправомерные информационные действия были совершены

А.Н. Ивановым?

Задача 4

Вы – начальник отдела по вопросам информационной безопасности в некоторой некрупной организации (20-30 человек).

Вам необходимо разработать требования к хранению, использованию и утилизации информации для вашей организации.

Цель: обеспечение информационной безопасности при хранении, обработке, передаче и уничтожении информации.

Задача 5

Проработайте требования для специалистов по подбору кадров вашей организации с целью внесения пунктов об информационной безопасности в трудовой договор новых сотрудников.

Цель: уведомление новых сотрудников о строгом выполнении требований по обеспечению информационной безопасности и ответственности за их нарушение.

Контрольные вопросы

1. Перечислите основополагающие документы по информационной безопасности.
2. Понятие государственной тайны.
3. Основные задачи информационной безопасности в соответствии с Концепцией национальной безопасности РФ.
4. Дайте характеристику Федерального закона от 27 июля 2006 г. № 149-ФЗ «Об информации, информационных технологиях и о защите информации».
5. Какая ответственность в Уголовном кодексе РФ предусмотрена за создание, использование и распространение вредоносных компьютерных программ?
6. Назовите 5 – 6 из 11 существующих функциональных требований стандарта ГОСТ Р ИСО/МЭК 15408-1-2012.
7. Для чего служит профиль защиты, согласно стандарту ГОСТ Р ИСО/МЭК 15408-1-2012?
8. Что прописано в Доктрине информационной безопасности РФ?
9. Чем отличаются функциональные требования от требований доверия, согласно стандарту ГОСТ Р ИСО/МЭК 15408-1-2012?
10. Что предполагает информационное обеспечение любой компании в целом?

Вариант 1

1. **Задача 1**: Разработайте 10 мероприятий по привлечению сторонних организаций к обработке информации согласно ГОСТ Р ИСО/МЭК 27002-2012.
2. **Задача 2**: Определите, нарушены ли авторские права гражданина Смирнова при модификации программы без его ведома. Ответ обоснуйте ссылкой на статью ГК РФ.
3. **Задача 3**: Сотрудник банка внедрил вирус, уничтоживший 60% ПО. Ущерб составил 500 тыс. руб. Определите статью УК РФ, предмет преступления и неправомерные действия.
4. **Задача 4**: Разработайте требования к хранению и утилизации информации для организации на 25 человек.
5. **Задача 5**: Разработайте 5 пунктов для трудового договора, касающихся ИБ.
6. **Контрольные вопросы**: Ответьте на вопросы 1, 3, 5, 7, 10.

Вариант 2

1. **Задача 1**: Разработайте 12 мероприятий по передаче ответственности за обработку информации сторонней организации.
2. **Задача 2**: Компания распространила модифицированную версию ПО без согласия автора. Какие права нарушены? Укажите статью ГК РФ.
3. **Задача 3**: Вирус заблокировал доступ к системе, ущерб 1,2 млн руб. Определите статью УК РФ, предмет и действия.
4. **Задача 4**: Составьте политику хранения и уничтожения данных для организации из 30 сотрудников.
5. **Задача 5**: Внесите в трудовой договор 3 обязательных пункта по ИБ.
6. **Контрольные вопросы**: Ответьте на вопросы 2, 4, 6, 8, 9.

Вариант 3

1. **Задача 1**: Предложите 15 мероприятий для обеспечения ИБ при аутсорсинге.
2. **Задача 2**: Автор передал права на распространение, но не на модификацию. Нарушены ли его права? Статья ГК РФ.
3. **Задача 3**: Внедрение вредоносной программы привело к утечке данных. Ущерб 300 тыс. руб. Определите статью УК РФ.
4. **Задача 4**: Разработайте правила использования и утилизации носителей информации.

5. **Задача 5**: Составьте памятку для новых сотрудников по ИБ.
6. **Контрольные вопросы**: Ответьте на вопросы 1, 2, 5, 6, 10.

Вариант 4

1. **Задача 1**: Разработайте 10 мер по контролю за сторонними обработчиками данных.
2. **Задача 2**: Компания изменила интерфейс ПО без уведомления автора. Нарушение? Статья ГК РФ.
3. **Задача 3**: Сотрудник скопировал базу данных клиентов. Ущерб 800 тыс. руб. Статья УК РФ, предмет, действия.
4. **Задача 4**: Составьте инструкцию по уничтожению конфиденциальных документов.
5. **Задача 5**: Включите в договор ответственность за разглашение коммерческой тайны.
6. **Контрольные вопросы**: Ответьте на вопросы 3, 4, 7, 8, 9.

Вариант 5

1. **Задача 1**: Предложите 18 мероприятий по обеспечению ИБ при передаче данных подрядчику.
2. **Задача 2**: Программа была распространена с изменениями, ухудшающими функционал. Нарушение? Статья ГК РФ.
3. **Задача 3**: Вредоносная программа шифровала файлы, ущерб 2 млн руб. Определите статью УК РФ.
4. **Задача 4**: Разработайте регламент резервного копирования и хранения данных.
5. **Задача 5**: Внесите в договор пункт об обязательном обучении ИБ.
6. **Контрольные вопросы**: Ответьте на вопросы 1, 3, 5, 6, 10.

Вариант 6

1. **Задача 1**: Разработайте 10 мер по оценке рисков при работе с подрядчиками.
2. **Задача 2**: Автор не давал согласия на изменение исходного кода. Нарушение? Статья ГК РФ.
3. **Задача 3**: Сотрудник получил несанкционированный доступ к системе, ущерб 400 тыс. руб. Статья УК РФ.

4. **Задача 4**: Составьте правила передачи информации внутри организации.
5. **Задача 5**: Включите в трудовой договор пункт о неразглашении персональных данных.
6. **Контрольные вопросы**: Ответьте на вопросы 2, 4, 7, 8, 9.

Вариант 7

1. **Задача 1**: Предложите 14 мер по обеспечению конфиденциальности при аутсорсинге.
2. **Задача 2**: Программа была модифицирована и продана как новая. Нарушение? Статья ГК РФ.
3. **Задача 3**: Вирус привел к простою системы, ущерб 1,5 млн руб. Определите статью УК РФ.
4. **Задача 4**: Разработайте инструкцию по работе с электронной почтой.
5. **Задача 5**: Внесите в договор пункт о периодической смене паролей.
6. **Контрольные вопросы**: Ответьте на вопросы 1, 2, 5, 6, 10.

Вариант 8

1. **Задача 1**: Разработайте 10 мероприятий по аудиту подрядчиков.
2. **Задача 2**: Автору не выплатили вознаграждение за использование ПО. Нарушение? Статья ГК РФ.
3. **Задача 3**: Сотрудник установил шпионское ПО, ущерб 600 тыс. руб. Статья УК РФ.
4. **Задача 4**: Составьте правила хранения бумажных носителей информации.
5. **Задача 5**: Включите в договор пункт о запрете установки неподтвержденного ПО.
6. **Контрольные вопросы**: Ответьте на вопросы 3, 4, 7, 8, 9.

Вариант 9

1. **Задача 1**: Предложите 16 мер по обеспечению целостности данных при передаче подрядчику.
2. **Задача 2**: Компания удалила имя автора из программы. Нарушение? Статья ГК РФ.
3. **Задача 3**: Вредоносная программа собирала данные о клиентах, ущерб 900 тыс. руб. Определите статью УК РФ.
4. **Задача 4**: Разработайте регламент уничтожения электронных носителей.

5. **Задача 5**: Внесите в договор пункт о ежеквартальной проверке соблюдения ИБ.
6. **Контрольные вопросы**: Ответьте на вопросы 1, 2, 5, 6, 10.

Вариант 10

1. **Задача 1**: Разработайте 10 мер по обучению сотрудников работе с подрядчиками.
2. **Задача 2**: Автор не был уведомлен о прекращении договора. Нарушение? Статья ГК РФ.
3. **Задача 3**: Сотрудник внес изменения в базу данных, ущерб 700 тыс. руб. Статья УК РФ.
4. **Задача 4**: Составьте правила использования облачных хранилищ.
5. **Задача 5**: Включите в договор пункт о немедленном увольнении за нарушение ИБ.
6. **Контрольные вопросы**: Ответьте на вопросы 3, 4, 7, 8, 9.